CRISC Exam - Hard Questions with Explanations

Each Option Analyzed

Open Source Community

October 25, 2026

Outline

1. Question 1: KRIs Maintenance
2. Question 2: Lessons Learned
3. Question 3: Positive Risk Response
4. Question 5: Risk Priority Number
5. Question 7: KRI Decision Makers
6. Question 8: Risk Scenario Requirements
7. Question 9: Risk Communications Plan
8. Question 11: Risk Identification Tools
9. Question 12: Risk Utility
10. Question 13: Monitoring Tool Scalability
11. Question 14: Risk Levels
12. Question 15: Grouping Risks by Cause
13. Question 16: Risk Communication Definition
14. Question 17: Risk Identification Output
15. Question 18: Risk Scenario Components
16. Question 19: Control Reliability
17. Question 20: Risk Maturity Level 1

Q1: Why Maintain KRIs?

Question

Which of the following is the MOST important reason to maintain key risk indicators (KRIs)?

A. In order to avoid risk
B. Complex metrics require fine-tuning
C. Risk reports need to be timely
D. Threats and vulnerabilities change over time

Q1: Explanation

Correct Answer: D

Threats and vulnerabilities change over time and KRI maintenance ensures that KRIs continue to effectively capture these changes.

Option Analysis

- **A - Incorrect:** Risk avoidance is a risk response, not a reason for KRI maintenance
- **B - Incorrect:** Fine-tuning is secondary; capturing changes is primary
- **C - Incorrect:** Timeliness is a business requirement, not a maintenance reason
- **D - Correct:** Risk environment is dynamic; KRIs must evolve with threats

Q2: Risk Responses After Project

Question

What should you do with the risk responses identified during the project's monitoring and controlling process after project completion?

A. Include in project management plan
B. Include in risk management plan
C. Include in lessons learned database
D. Nothing - already in risk register

Q2: Explanation

Correct Answer: C

Risk responses should be included in the organization's lessons learned database so other project managers can use them.

Option Analysis

- **A - Incorrect:** Project management plan is for current project execution
- **B - Incorrect:** Risk management plan is for current project methodology
- **C - Correct:** Knowledge sharing benefits future projects
- **D - Incorrect:** Risk register alone doesn't share knowledge across projects

Q3: Risk That Saves Money

Question

You identified a risk event that could save $100,000 in project costs if it occurs. Which statement BEST describes this risk event?

A. Should be mitigated
B. Should be accepted
C. Should be avoided
D. This is an opportunity and should be exploited

Q3: Explanation

Correct Answer: D

This risk event has potential to save money, so it is an opportunity. The appropriate strategy is to exploit it.

Option Analysis

- **A - Incorrect:** Mitigation is for negative risks, not positive opportunities
- **B - Incorrect:** Acceptance is passive; opportunity deserves active exploitation
- **C - Incorrect:** Avoidance is for negative risks, prevents opportunity
- **D - Correct:** Exploiting ensures the opportunity is realized

Q5: RPN Calculation

Question

A risk has rating for occurrence, severity, and detection as 4, 5, and 6 respectively. What Risk Priority Number (RPN) would you give?

- A 120
- B 100
- C 15
- D 30

Q5: Explanation

Correct Answer: A

RPN = Severity $\times$ Occurrence $\times$ Detection = $4 \times 5 \times 6 = 120$

Option Analysis

- **A - Correct:** $4 \times 5 \times 6 = 120$
- **B - Incorrect:** Would be sum of values multiplied incorrectly
- **C - Incorrect:** This would be addition (4+5+6=15)
- **D - Incorrect:** This ignores one factor (4×5=20 or 5×6=30)

Q7: Who Decides KRIs? Who gives perspective and who approves

Question

Which role carriers decide the Key Risk Indicators of the enterprise? (Choose two)

- A Business leaders
- B Senior management
- C Human resources
- D Chief financial officer

Q7: Explanation

Correct Answer: A and B

CRISC works with senior management and business leaders to determine which risk indicators become KRIs.

Option Analysis

- **A - Correct:** Business leaders provide strategic risk perspective
- **B - Correct:** Senior management approves KRIs
- **C - Incorrect:** HR oversees risk culture, not KRI selection
- **D - Incorrect:** CFO oversees financial risks only

Q8: Risk Scenario Requirements

Question

What are the requirements for creating risk scenarios? (Choose three)

- A Determination of cause and effect
- B Determination of value of business process at risk
- C Potential threats and vulnerabilities that could cause loss
- D Determination of value of an asset

Q8: Explanation

Correct Answer: B, C, D

Creating risk scenarios requires: value of asset/business process at risk, and potential threats/vulnerabilities.

Option Analysis

- **A - Incorrect:** Cause-effect is predictive analysis, not scenario creation
- **B - Correct:** Business process value is essential for scenario
- **C - Correct:** Threats and vulnerabilities define potential loss
- **D - Correct:** Asset value is fundamental to risk quantification

Q9: Who Shares Risk Information?

Question

Which project management plan defines who will be available to share information on project risks?

A. Resource Management Plan
B. Risk Management Plan
C. Stakeholder Management Strategy
D. Communications Management Plan

Q9: Explanation

Correct Answer: D

The Communications Management Plan defines who will be available to share information on risks and responses throughout the project.

Option Analysis

- **A - Incorrect:** Resource Management Plan doesn't define risk communications
- **B - Incorrect:** Risk Management Plan defines analysis and responses, not communication roles
- **C - Incorrect:** Stakeholder strategy doesn't address risk communications
- **D - Correct:** Communications Plan defines roles for sharing risk information

Q11: NOT Used in Risk Identification

Question

Which tool is NOT used for identifying project risks?

A. Process flowchart
B. Ishikawa diagram
C. Influence diagram
D. Decision tree diagram

Q11: Explanation

Correct Answer: D

Decision tree diagrams are used during Quantitative risk analysis, not in risk identification.

Option Analysis

- **A - Incorrect:** Process flowchart is used in identification
- **B - Incorrect:** Ishikawa diagram identifies causes
- **C - Incorrect:** Influence diagram shows relationships
- **D - Correct:** Decision tree is for quantitative analysis, not identification

Practice: Process Flowchart

Question

Which tool is MOST useful for identifying risks by mapping process steps and locating potential failure points?

A. Decision tree diagram
B. Process flowchart
C. Tornado diagram
D. Sensitivity analysis

Answer

Correct Answer: B

Process flowcharts help identify risks by visualizing process activities and workflow dependencies.

Practice: Ishikawa Diagram

Question

Which tool is BEST used to identify root causes of a problem or risk event?

A. Decision tree diagram
B. Influence diagram
C. Ishikawa diagram
D. Control chart

Answer

Correct Answer: C

Ishikawa (fishbone) diagrams are used to identify and categorize root causes of risks and problems.

Practice: Influence Diagram

Question

Which tool is used to show relationships and dependencies among variables that may affect project outcomes?

A. Influence diagram
B. Pareto chart
C. Decision tree diagram
D. Work breakdown structure

Answer

Correct Answer: A

Influence diagrams illustrate relationships between decisions, uncertainties, and objectives.

Practice: Decision Tree Diagram

Question

Which tool is MOST commonly used during quantitative risk analysis to evaluate alternative decisions and their expected outcomes?

A. Process flowchart
B. Ishikawa diagram
C. Decision tree diagram
D. Risk breakdown structure

Answer

Correct Answer: C

Decision tree diagrams are used for quantitative risk analysis and expected monetary value calculations.

Q12: Definition of Risk Utility

Question

Which BEST describes the utility of a risk?

A. The finance incentive behind the risk
B. The potential opportunity of the risk
C. The mechanics of how a risk works
D. The usefulness of the risk to individuals or groups

Q12: Explanation

Correct Answer: D

Risk utility describes the usefulness of a particular risk to an individual or group.

Option Analysis

- **A - Incorrect:** Finance incentive is a measurement method, not definition
- **B - Incorrect:** This describes opportunity, not utility
- **C - Incorrect:** This describes risk mechanics, not utility
- **D - Correct:** Utility = usefulness/benefit to stakeholders

Q13: Monitoring Tool Growth Ability

Question

Which monitoring tool aspect ensures ability to keep up with enterprise growth?

A. Scalability
B. Customizability
C. Sustainability
D. Impact on performance

Q13: Explanation

Correct Answer: A

Scalability ensures monitoring tools can meet anticipated growth in process, complexity, or transaction volumes.

Option Analysis

- **A - Correct:** Scalability is about growth capacity
- **B - Incorrect:** Customizability is about adapting to needs
- **C - Incorrect:** Sustainability is about long-term effectiveness
- **D - Incorrect:** Performance impact is separate from growth ability

Q14: Moderate Risk Definition

Question

A risk that is a noticeable failure threatening the success of certain goals exists at which level?

A. Moderate risk
B. High risk
C. Extremely high risk
D. Low risk

Q14: Explanation

Correct Answer: A

Moderate risks are noticeable failures threatening the success of certain goals.

Option Analysis

- **A - Correct:** Moderate = noticeable failure affecting specific goals
- **B - Incorrect:** High = significant failure impacting multiple goals
- **C - Incorrect:** Extremely high = large impact, likely failure with severe consequences
- **D - Incorrect:** Low = results in certain unsuccessful goals (minimal)

Q15: Grouping Risks by Common Causes

Question

What is the primary advantage to group risks by common causes during qualitative risk analysis?

A. Realize areas most laden with risks
B. Assist in developing effective risk responses
C. Save time by collecting related resources
D. Create risk categories unique to each project

Q15: Explanation

Correct Answer: B

By grouping risks by categories, the project team can develop effective risk responses. Related risks often have common causal factors.

Option Analysis

- **A - Incorrect:** This is a byproduct, not primary advantage
- **B - Correct:** Common causes can be addressed with single response
- **C - Incorrect:** Time savings is secondary to response effectiveness
- **D - Incorrect:** Categories may be organizational, not unique

Q16: Risk Communication Process

Question

"Process of exchanging information and views about risks among stakeholders" describes which process?

A. Risk governance
B. Risk identification
C. Risk response planning
D. Risk communication

Q16: Explanation

Correct Answer: D

Risk communication is exactly defined as exchanging information and views about risks among stakeholders.

Option Analysis

- **A - Incorrect:** Governance is about decision-making structures
- **B - Incorrect:** Identification is about discovering risks
- **C - Incorrect:** Response planning is about mitigation actions
- **D - Correct:** Communication is information exchange

Q17: Key Output of Identify Risk Process

Question

Which is a key output of the Identify Risks process?

A. Risk Register
B. Risk Management Plan
C. Risk Breakdown Structure
D. Risk Categories

Q17: Explanation

Correct Answer: A

The primary output from Identify Risks is the initial entries into the risk register.

Option Analysis

- **A - Correct:** Risk register is the only output of Identify Risks
- **B - Incorrect:** Risk Management Plan is from Plan Risk Management
- **C - Incorrect:** RBS is from Plan Risk Management
- **D - Incorrect:** Categories are from Plan Risk Management

Q18: Component Generating Threat

Question

Which risk scenario component has potential to generate internal or external threat?

A. Timing dimension
B. Events
C. Assets
D. Actors

Q18: Explanation

Correct Answer: D

Actors are those components that have the potential to generate the threat (internal or external, human or non-human).

Option Analysis

- **A - Incorrect:** Timing dimension is about when, not threat generation
- **B - Incorrect:** Events are happenings, not threat generators
- **C - Incorrect:** Assets are what need protection, not threat sources
- **D - Correct:** Actors generate threats (staff, competitors, outsiders)

Q19: Before Relying on Controls

Question

What should you do before relying on any control?

- A Review performance data
- B Discover risk exposure
- C Conduct pilot testing
- D Articulate risk

Q19: Explanation

Correct Answer: A and C

Pilot testing and reviewing performance data to verify operation against design are done before relying on control.

Option Analysis

- **A - Correct:** Performance data verifies control operation
- **B - Incorrect:** Risk exposure helps identify severity, not control reliability
- **C - Correct:** Pilot testing validates control effectiveness
- **D - Incorrect:** Articulating risk is first phase, doesn't verify control

Q20: NOT True for Maturity Level 1

Question

Which statement is NOT true for risk management capability maturity level 1?

A. Risk is viewed as technical issue
B. Decisions involving risk lack credible information
C. Risk appetite applied only during episodic assessments
D. Risk management skills exist on ad hoc basis

Q20: Explanation

Correct Answer: B

Decisions lacking credible information is a characteristic of Level 0, not Level 1.

Option Analysis

- **A - True:** Level 1 views risk as technical issue
- **B - Not True:** This is Level 0 characteristic
- **C - True:** Level 1 has episodic risk appetite application
- **D - True:** Level 1 has ad hoc risk management skills

Practice: Level 0 Characteristic

Question

Which statement is MOST characteristic of risk management capability maturity level 0?

A. Risk appetite is applied during periodic assessments
B. Risk management skills exist on an ad hoc basis
C. Decisions involving risk lack credible information
D. Risk is viewed as a business issue

Practice: Explanation

Correct Answer: C

Decisions involving risk lack credible information is a defining characteristic of Level 0.

Practice: Maturity Level

Question

Risk management activities are performed inconsistently, skills exist on an ad hoc basis, and risk is primarily viewed as a technical issue. Which maturity level BEST describes this organization?

- A Level 0
- B Level 1
- C Level 2
- D Level 3

Practice: Explanation

Correct Answer: B

These are classic characteristics of Risk Maturity Level 1.

Practice: NOT Level 0

Question

Which statement is NOT characteristic of risk management capability maturity level 0?

A. Risk decisions lack credible information
B. Risk management is largely nonexistent
C. Risk management skills exist on an ad hoc basis
D. Risk is rarely considered in decision making

Practice: Explanation

Correct Answer: C

Ad hoc risk management skills are associated with Level 1, not Level 0.

Practice: Comparison

Question

What is the PRIMARY difference between maturity Level 0 and Level 1?

A. Level 1 introduces some informal risk management practices
B. Level 1 has optimized risk management
C. Level 0 has a formal risk appetite framework
D. Level 0 performs continuous risk monitoring

Practice: Explanation

Correct Answer: A

Level 1 organizations begin to perform risk management activities informally, while Level 0 organizations have little or no formal capability.

Practice: Hard

Question

An organization occasionally discusses risk during major projects. Risk appetite is considered only during periodic assessments, and risk expertise depends on individual employees rather than established processes. What maturity level BEST fits this organization?

A. Level 0
B. Level 1
C. Level 2
D. Level 4

Practice: Explanation

Correct Answer: B

Episodic risk appetite application and ad hoc risk management skills are key indicators of Level 1 maturity.

Q21: Most Important for Risk Review

Question

Which stakeholder is MOST important for reviewing risk response options?

A. Information security managers
B. Internal auditors
C. Incident response team members
D. Business managers

Q21: Explanation

Correct Answer: D

Business managers are accountable for managing associated risk and determine actions based on information provided by others.

Option Analysis

- **A - Incorrect:** Security managers understand technical aspects but business managers decide
- **B - Incorrect:** Auditors provide assurance, not decision-making
- **C - Incorrect:** Incident team responds to events, doesn't review options
- **D - Correct:** Business managers are accountable and decide actions

Q22

Question

Which technique provides systematic description of unwanted occurrences in a system?

A. Sensitivity analysis
B. Scenario analysis
C. Fault tree analysis
D. Cause and effect analysis

Q22: Explanation

Correct Answer: C

Fault Tree Analysis (FTA) provides systematic description of possible occurrences that can result in undesirable outcomes.

Option Analysis

- **A - Incorrect:** Sensitivity examines input uncertainty impact
- **B - Incorrect:** Scenario shows range of values across scenarios
- **C - Correct:** FTA combines hardware and human failures
- **D - Incorrect:** Cause-effect explores root causes

Q23: Risk Treatment Definition

Question

What is the process for selecting and implementing measures to impact risk called?

- A Risk Treatment
- B Control
- C Risk Assessment
- D Risk Management

Q23: Explanation

Correct Answer: A

Risk treatment is the process for selecting and implementing measures for impacting risk in the environment.

Option Analysis

- **A - Correct:** Treatment specifically addresses implementation
- **B - Incorrect:** Control is one type of measure, not the process
- **C - Incorrect:** Assessment is analyzing and evaluating, not implementing
- **D - Incorrect:** Management is broader coordinated activities

Practice: Risk Response Activities

Question

A risk manager evaluates several response options and decides to implement additional monitoring controls to reduce the likelihood of a loss event. Which process is being performed?

- A Risk Treatment
- B Risk Identification
- C Risk Analysis
- D Risk Appetite Definition

Practice: Explanation

Correct Answer: A

Risk treatment involves selecting and implementing measures to modify, mitigate, transfer, avoid, or accept risk.

Option Analysis

- **A - Correct:** The organization is implementing controls to affect risk.
- **B - Incorrect:** Risk identification focuses on discovering and documenting risks, not responding to them.
- **C - Incorrect:** Risk analysis evaluates likelihood and impact but does not implement responses.
- **D - Incorrect:** Risk appetite defines acceptable risk levels and tolerance, not specific response actions.

Practice: Control or Process

Question

Which of the following represents a risk treatment activity rather than a control?

A. Selecting a strategy to transfer cyber risk through insurance
B. Multi-factor authentication
C. Segregation of duties
D. Automated transaction monitoring

Practice: Explanation

Correct Answer: A

Risk treatment is the overall process of selecting actions to address risk. Purchasing insurance is a treatment decision.

Option Analysis

- **A - Correct:** Risk transfer through insurance is a risk treatment strategy.
- **B - Incorrect:** Multi-factor authentication is a control implemented as part of treatment.
- **C - Incorrect:** Segregation of duties is a preventive control.
- **D - Incorrect:** Transaction monitoring is a detective control.

Practice: Next Step

Question

After risk analysis determines that a risk exceeds management's tolerance level, what should occur NEXT?

A. Risk Treatment
B. Risk Identification
C. Asset Valuation
D. Business Case Development

Practice: Explanation

Correct Answer: A

Once a risk has been assessed and determined to exceed tolerance, risk treatment activities should be selected and implemented.

Option Analysis

- **A - Correct:** Treatment follows assessment when action is required.
- **B - Incorrect:** Identification occurs earlier in the risk management lifecycle.
- **C - Incorrect:** Asset valuation supports assessment but is not the next step.
- **D - Incorrect:** A business case may be created for specific initiatives but is not the formal risk management step.

Q24: Sarbanes-Oxley Section 302

Question

Which SOX section specifies "Periodic financial reports must be certified by CEO and CFO"?

A. Section 302
B. Section 404
C. Section 203
D. Section 409

Q24: Explanation

Correct Answer: A

Section 302 requires corporate responsibility for financial reports to be certified by CEO, CFO, or designated representative.

Option Analysis

- **A - Correct:** Section 302 is certification requirement
- **B - Incorrect:** Section 404 is annual internal controls assessment
- **C - Incorrect:** Section 203 is audit partner rotation
- **D - Incorrect:** Section 409 is timely financial reporting

Q25: Primary Need for Control Assessment

Question

What is the PRIMARY need for effectively assessing controls?

A. Control's alignment with operating environment
B. Control's design effectiveness
C. Control's objective achievement
D. Control's operating effectiveness

Q25: Explanation

Correct Answer: C

Controls can be effectively assessed only by determining how accurately the control objective is achieved within the operating environment.

Option Analysis

- **A - Incorrect:** Alignment is essential but secondary to objective achievement
- **B - Incorrect:** Design effectiveness is considered after objectives
- **C - Correct:** Objective achievement is the top priority
- **D - Incorrect:** Operating effectiveness is considered but after objectives

Q26: Fast Tracking Effect

Question

When you fast track the project, what is likely to increase?

A. Human resource needs
B. Quality control concerns
C. Costs
D. Risks

Q26: Explanation

Correct Answer: D

Fast tracking allows phases to overlap and generally increases risks within the project.

Option Analysis

- **A - Incorrect:** HR is not typically affected by fast tracking
- **B - Incorrect:** Quality concerns usually not affected
- **C - Incorrect:** Costs don't generally increase from fast tracking
- **D - Correct:** Overlapping phases introduces more risk

Q27: Identifying Risk Response Type

Question

David takes actions to ensure risk event doesn't happen, costing $10,000. What risk response is this?

A. Avoidance
B. Mitigation
C. Acceptance
D. Transfer

Q27: Explanation

Correct Answer: B

Taking operational controls to reduce likelihood and impact of risk is risk mitigation.

Option Analysis

- **A - Incorrect:** Avoidance discontinues activities causing risk
- **B - Correct:** Actions reduce probability and/or impact
- **C - Incorrect:** Acceptance means no action taken
- **D - Incorrect:** Transfer would involve third party

Q28: Most Important IS Control Objective

Question

What is the MOST important objective of information system control?

A. Business objectives achieved, undesired risk detected/corrected
B. Ensuring effective and efficient operations
C. Developing business continuity plans
D. Safeguarding assets

Q28: Explanation

Correct Answer: A

The basic purpose of IS control is to ensure business objectives are achieved and undesired risk events are detected and corrected.

Option Analysis

- **A - Correct:** Primary purpose - business objectives + risk detection
- **B - Incorrect:** This is one objective but not the most important
- **C - Incorrect:** This is one objective but not the most important
- **D - Incorrect:** This is one objective but not the most important

Q29: Starting Point for IT Service Continuity

Question

Which is prepared by business and serves as starting point for IT Service Continuity Strategy?

A. Business Continuity Strategy
B. Index of Disaster-Relevant Information
C. Disaster Invocation Guideline
D. Testing Schedule

Q29: Explanation

Correct Answer: A

Business Continuity Strategy is outline of approach to ensure continuity of Vital Business Functions, prepared by business.

Option Analysis

- **A - Correct:** Business creates BCS which informs IT strategy
- **B - Incorrect:** Index is IT document for disaster information
- **C - Incorrect:** Guideline is IT document with disaster instructions
- **D - Incorrect:** Testing Schedule is IT operational document

Q30: Maturity Level XX Statement

Question

"Real-time monitoring of risk events and control exceptions exists, as does automation of policy management" describes which level?

- A Level 3
- B Level 0
- C Level 5
- D Level 2

Q30: Explanation

Correct Answer: C

Risk management capability maturity level 5 has real-time monitoring and automation of policy management.

Option Analysis

- **A - Incorrect:** Level 3 doesn't have real-time monitoring
- **B - Incorrect:** Level 0 doesn't recognize risk management
- **C - Correct:** Level 5 has real-time monitoring and automation
- **D - Incorrect:** Level 2 doesn't have real-time monitoring

Q31: CPI True Statement

Question

Which is true for Cost Performance Index (CPI)?

A. If CPI greater than 1, it indicates better than expected performance

B. CPI = EV × AC

C. CPI is used to measure schedule performance

D. If CPI = 1, it indicates poor performance

Q31: Explanation

Correct Answer: A

CPI = EV/AC. If CPI greater than 1, indicates better than expected performance. CPI = 1 indicates right on target.

Option Analysis

- **A - Correct:** greater than 1 = better than expected performance
- **B - Incorrect:** CPI = EV/AC, not EV × AC
- **C - Incorrect:** CPI measures cost performance, not schedule
- **D - Incorrect:** CPI = 1 indicates right on target

Practice: CPI Interpretation

Question

A project has an Earned Value (EV) of $200,000 and an Actual Cost (AC) of $250,000. What can be concluded?

A. The project is under budget
B. CPI is 1.25, indicating efficient cost performance
C. CPI is 0.80, indicating the project is over budget
D. SPI is 0.80, indicating schedule variance

Practice: Explanation

Correct Answer: C

CPI = EV/AC = 200,000/250,000 = 0.80. A CPI less than 1 indicates the project is spending more than planned for the work completed.

Option Analysis

- **A - Incorrect:** A CPI below 1 means the project is over budget, not under budget.
- **B - Incorrect:** The formula was calculated incorrectly. CPI equals 0.80, not 1.25.
- **C - Correct:** CPI below 1 indicates unfavorable cost performance and budget overruns.
- **D - Incorrect:** SPI measures schedule performance and cannot be calculated without Planned Value (PV).

Practice: Performance Metrics

Question

Which statement BEST distinguishes CPI from SPI?

A. CPI measures schedule efficiency while SPI measures cost efficiency
B. CPI measures cost efficiency while SPI measures schedule efficiency
C. Both CPI and SPI measure cost efficiency
D. Both CPI and SPI measure schedule efficiency

Practice: Explanation

Correct Answer: B

CPI evaluates cost performance, while SPI evaluates schedule performance.

Option Analysis

- **A - Incorrect:** The definitions are reversed.
- **B - Correct:** CPI focuses on cost, SPI focuses on schedule.
- **C - Incorrect:** SPI does not measure cost performance.
- **D - Incorrect:** CPI does not measure schedule performance.

Practice: CPI Values

Question

Which statement regarding CPI is TRUE?

A. CPI less than 1 indicates favorable cost performance
B. CPI greater than 1 indicates the project is getting less value per dollar spent
C. CPI equal to 1 indicates actual cost equals earned value
D. CPI is calculated as AC/EV

Practice: Explanation

Correct Answer: C

CPI = EV/AC. A CPI of exactly 1 means earned value equals actual cost.

Option Analysis

- **A - Incorrect:** CPI below 1 indicates poor cost performance and cost overruns.
- **B - Incorrect:** CPI above 1 indicates favorable cost performance and greater value per dollar spent.
- **C - Correct:** EV equals AC when CPI equals 1.
- **D - Incorrect:** The formula is EV/AC, not AC/EV.

Q32: NOT Indirect Information

Question

Which does NOT provide indirect information?

- A Information about propriety of cutoff
- B Reports of orders rejected for credit limitations
- C Reports of unusual deviations
- D No significant differences between perpetual and actual levels

Q32: Explanation

Correct Answer: A

Information about propriety of cutoff is direct information, not indirect.

Option Analysis

- **A - Correct:** Propriety of cutoff is direct evidence
- **B - Incorrect:** Rejected orders gives indirect info about credit controls
- **C - Incorrect:** Unusual deviations gives indirect info about billing controls
- **D - Incorrect:** No differences gives indirect info about billing controls

Q33: Salience Model Description

Question

Which activity best describes a salience model?

A. Power, urgency, and legitimacy
B. Power and interest
C. Influence and impact
D. Power and influence

Q33: Explanation

Correct Answer: A

Salience model describes stakeholders based on power (ability to impose will), urgency (need for attention), and legitimacy (appropriate involvement).

Option Analysis

- **A - Correct:** Power, urgency, legitimacy = salience model
- **B - Incorrect:** This is power/interest grid
- **C - Incorrect:** This is influence/impact grid
- **D - Incorrect:** This is power/influence grid

Q34: First Step in Risk Assessment

Question

What is the first step in the risk assessment process?

- A Identification of assets
- B Identification of threats
- C Identification of threat sources
- D Identification of vulnerabilities

Q34: Explanation

Correct Answer: A

Asset identification is the most crucial and first step in the risk assessment process.

Option Analysis

- **A - Correct:** Assets come first (people, processes, infrastructure)
- **B - Incorrect:** Threats come after asset identification
- **C - Incorrect:** Threat sources come after assets
- **D - Incorrect:** Vulnerabilities come after threat identification

Q35: Risk Threshold Specification

Question

Which matrix is used to specify risk thresholds?

A. Risk indicator matrix
B. Impact matrix
C. Risk scenario matrix
D. Probability matrix

Q35: Explanation

Correct Answer: A

Risk indicators are metrics used to indicate risk thresholds - when risk level is approaching high or unacceptable level.

Option Analysis

- **A - Correct:** Risk indicators specifically show thresholds
- **B - Incorrect:** Impact matrix helps rating risks, not thresholds
- **C - Incorrect:** Scenario matrix describes events, not thresholds
- **D - Incorrect:** Probability matrix helps rating risks, not thresholds

Q36: Major Risk Appetite Factors

Question

What are the two MAJOR factors for deciding risk appetite? (Choose two)

- A Amount of loss enterprise wants to accept
- B Alignment with risk-culture
- C Risk-aware decisions
- D Capacity to absorb loss

Q36: Explanation

Correct Answer: A and D

Two major factors: (1) capacity to absorb loss, (2) culture towards risk taking - amount of loss enterprise wants to accept.

Option Analysis

- **A - Correct:** Amount of loss to accept is key factor
- **B - Incorrect:** Alignment with risk-culture is secondary
- **C - Incorrect:** Risk-aware decisions are results, not factors
- **D - Correct:** Capacity to absorb loss is key factor

Q37: Process Responsible for Risk Updates

Question

Which process is responsible for identifying new risks, changing risks, and outdated risks?

A. Risk planning
B. Risk monitoring and controlling
C. Risk identification
D. Risk analysis

Q37: Explanation

Correct Answer: B

Risk monitoring and controlling is responsible for identifying new risks, determining status of changed risks, and outdated risks.

Option Analysis

- **A - Incorrect:** Planning creates methodology
- **B - Correct:** Monitoring tracks risk status changes
- **C - Incorrect:** Identification happens before analysis
- **D - Incorrect:** Analysis determines severity, not dynamic changes

Q38: SLE Calculation

Question

Asset valued at $125,000 subjected to exposure factor of 25%. What is Single Loss Expectancy?

- A $125,025
- B $31,250
- C $5,000
- D $3,125,000

Q38: Explanation

Correct Answer: B

SLE = Asset Value × Exposure Factor = $125,000 × 0.25 = $31,250

Option Analysis

- **A - Incorrect:** $125,025 is adding instead of multiplying
- **B - Correct:** $125,000 × 0.25 = $31,250
- **C - Incorrect:** $5,000 = incorrect calculation
- **D - Incorrect:** $3,125,000 is dividing instead of multiplying

Q39: Access Control Principles

Question

Which are principles of access controls? (Choose three)

- A Confidentiality
- B Availability
- C Reliability
- D Integrity

Q39: Explanation

Correct Answer: A, B, D

Access controls focus on Confidentiality, Integrity, and Availability (CIA triad).

Option Analysis

- **A - Correct:** Confidentiality is core principle
- **B - Correct:** Availability is core principle
- **C - Incorrect:** Reliability is not a CIA principle
- **D - Correct:** Integrity is core principle

Q40: Maintaining KRIs Reason

Question

What is the MOST important reason to maintain Key Risk Indicators?

A. Risk reports need to be timely

B. Complex metrics require fine-tuning

C. Threats and vulnerabilities change over time

D. They help to avoid risk

Q40: Explanation

Correct Answer: C

Since internal and external environments constantly change, KRIs need to effectively capture these changes.

Option Analysis

- **A - Incorrect:** Timeliness is business requirement, not maintenance reason
- **B - Incorrect:** Fine-tuning is secondary to capturing changes
- **C - Correct:** Threats and vulnerabilities change over time
- **D - Incorrect:** Avoiding risk is a response, not maintenance reason

Q41: NOT Technical Control

Question

Which control does NOT come under technical class of control?

- A Program management control
- B System and Communications Protection control
- C Identification and Authentication control
- D Access Control

Q41: Explanation

Correct Answer: A

Program Management control comes under management class of controls, not technical.

Option Analysis

- **A - Correct:** Program Management is management class
- **B - Incorrect:** SC family is technical class
- **C - Incorrect:** IA family is technical class
- **D - Incorrect:** AC family is technical class

Q42: Risk Identification Method

Question

Mary uses a facilitator to help generate ideas about project risks. What method is she using?

A. Delphi Techniques
B. Expert judgment
C. Brainstorming
D. Checklist analysis

Q42: Explanation

Correct Answer: C

Brainstorming attempts to create a comprehensive list of risks and is often led by a moderator or facilitator.

Option Analysis

- **A - Incorrect:** Delphi uses anonymous surveys, no facilitator
- **B - Incorrect:** Expert judgment is individual assessment
- **C - Correct:** Brainstorming uses facilitator for idea generation
- **D - Incorrect:** Checklist uses historical information

Practice: Technique

Question

A project manager wants to gather risk opinions from subject matter experts located across several countries. The experts should not know one another's identities in order to avoid bias and group influence. Which technique is MOST appropriate?

- A Brainstorming
- B Checklist Analysis
- C Delphi Technique
- D Expert Judgment

Practice: Explanation

Correct Answer: C

The Delphi Technique uses anonymous expert input collected through multiple rounds to achieve consensus while reducing bias.

Option Analysis

- **A - Incorrect:** Brainstorming involves open discussion rather than anonymous feedback.
- **B - Incorrect:** Checklist analysis relies on historical risk lists and templates.
- **C - Correct:** Delphi uses anonymous expert surveys to build consensus.
- **D - Incorrect:** Expert judgment may involve experts, but anonymity is not required.

Practice: Expert Judgment

Question

The project manager consults a senior cybersecurity specialist with 25 years of experience to evaluate the likelihood of a ransomware attack. Which risk identification technique is being used?

A. Expert Judgment
B. Delphi Technique
C. Brainstorming
D. Checklist Analysis

Practice: Explanation

Correct Answer: A

Expert judgment uses the knowledge and experience of individuals with specialized expertise.

Option Analysis

- **A - Correct:** A subject matter expert is providing a professional assessment.
- **B - Incorrect:** Delphi requires multiple anonymous experts.
- **C - Incorrect:** Brainstorming involves group idea generation.
- **D - Incorrect:** Checklist analysis relies on documented historical risks.

Practice

Question

A facilitator gathers representatives from compliance, technology, operations, and audit into a workshop to generate as many potential project risks as possible. Which technique is being used?

- A Brainstorming
- B Delphi Technique
- C Expert Judgment
- D Checklist Analysis

Practice: Explanation

Correct Answer: A

Brainstorming is a group creativity technique used to generate a comprehensive list of risks.

Option Analysis

- **A - Correct:** Facilitated group discussion is the hallmark of brainstorming.
- **B - Incorrect:** Delphi avoids direct interaction among participants.
- **C - Incorrect:** Expert judgment usually relies on individual expertise.
- **D - Incorrect:** Checklist analysis reviews predefined risk lists.

Practice

Question

A risk analyst reviews lessons learned and risk registers from similar projects and compares them against a predefined list of common risks. Which technique is being used?

- A Brainstorming
- B Expert Judgment
- C Checklist Analysis
- D Delphi Technique

Practice: Explanation

Correct Answer: C

Checklist analysis identifies risks using historical information and predefined risk categories.

Option Analysis

- **A - Incorrect:** Brainstorming creates new ideas through discussion.
- **B - Incorrect:** Expert judgment uses individual expertise rather than historical checklists.
- **C - Correct:** Checklist analysis relies on established risk lists and prior experience.
- **D - Incorrect:** Delphi uses anonymous expert feedback rather than documented checklists.

Q43: Administrative Control Example

Question

Which is an administrative control?

- A Water detection
- B Reasonableness check
- C Data loss prevention program
- D Session timeout

Q43: Explanation

Correct Answer: C

Data Loss Prevention program is an administrative control (program consists of projects, policies).

Option Analysis

- **A - Incorrect:** Water detection is physical/technical
- **B - Incorrect:** Reasonableness check is technical
- **C - Correct:** DLP program is administrative
- **D - Incorrect:** Session timeout is technical

Q44: Plan Creation

Question

What document defines how risks will be identified, quantified, and contingency plans implemented?

A. Project plan
B. Resource management plan
C. Project management plan
D. Risk management plan

Q44: Explanation

Correct Answer: D

Risk management plan defines how risks will be identified, analyzed, monitored, controlled, and responded to.

Option Analysis

- **A - Incorrect:** Project plan is not official PMBOK plan
- **B - Incorrect:** Resource plan manages people/equipment
- **C - Incorrect:** PM plan is overarching, not risk-specific
- **D - Correct:** Risk management plan specifically addresses risk

Q45: Where Risks and Responses are Documented

Question

Where are all risks and risk responses documented as project progresses?

A. Risk management plan
B. Project management plan
C. Risk response plan
D. Risk register

Q45: Explanation

Correct Answer: D

All risks, their responses, and other characteristics are documented in the risk register.

Option Analysis

- **A - Incorrect:** Risk Management Plan is methodology, not documentation
- **B - Incorrect:** PM plan is overarching
- **C - Incorrect:** Risk response plan addresses planned responses only
- **D - Correct:** Risk register is the repository for all risk information

Q46: Hiring Third Party

Question

Hiring a company to deal with all hardware work is which type of risk response?

A. Transference
B. Mitigation
C. Avoidance
D. Exploit

Q46: Explanation

Correct Answer: A

Hiring a third party to own risk is risk transference.

Option Analysis

- **A - Correct:** Transfer risk to another party
- **B - Incorrect:** Mitigation is spending money to reduce risk
- **C - Incorrect:** Avoidance adds activities to prevent risk
- **D - Incorrect:** Exploit is for positive risks/opportunities

Q47: Risk Identification Input

Question

Which input of identify risks process helps identify risks associated with time allowances?

A. Activity duration estimates
B. Activity cost estimates
C. Risk management plan
D. Schedule management plan

Q47: Explanation

Correct Answer: A

Activity duration estimates review helps identify risks associated with time allowances, with width of range indicating risk degree.

Option Analysis

- **A - Correct:** Duration estimates identify time risks
- **B - Incorrect:** Cost estimates identify cost risks
- **C - Incorrect:** Risk plan identifies methodology
- **D - Incorrect:** Schedule plan describes reporting

Q48: Loss of Integrity Events

Question

Which events refer to loss of integrity? (Choose three)

- A Someone sees company's secret formula
- B Someone makes unauthorized changes to a Web site
- C An e-mail message is modified in transit
- D A virus infects a file

Q48: Explanation

Correct Answer: B, C, D

Loss of integrity includes: message modified in transit, virus infects file, unauthorized Web site changes.

Option Analysis

- **A - Incorrect:** Seeing secret formula = loss of confidentiality
- **B - Correct:** Unauthorized changes = integrity loss
- **C - Correct:** Message modified = integrity loss
- **D - Correct:** Virus infects file = integrity loss

Q49: First Step in IS Control Design

Question

What should be PRIMARILY considered while designing information systems controls?

A. The IT strategic plan
B. The existing IT environment
C. The organizational strategic plan
D. The present IT budget

Q49: Explanation

Correct Answer: C

Review of enterprise's strategic plan is the first step in designing effective IS controls that fit enterprise's long-term plans.

Option Analysis

- **A - Incorrect:** IT plan supports enterprise plan, not primary
- **B - Incorrect:** Existing environment review is useful but secondary
- **C - Correct:** Organizational strategic plan is primary
- **D - Incorrect:** Budget is one component, not primary

Q50: Most Effective Communication Inhibitor

Question

Which is the MOST effective inhibitor of relevant and efficient communication?

A. False sense of confidence at top
B. Perception of covering up known risk
C. Existence of a blame culture
D. Misalignment between risk appetite and policies

Q50: Explanation

Correct Answer: C

Blame culture is the most effective inhibitor. Business units point fingers at IT when projects fail.

Option Analysis

- **A - Incorrect:** This is consequence of poor communication
- **B - Incorrect:** This is consequence of poor communication
- **C - Correct:** Blame culture directly inhibits collaboration
- **D - Incorrect:** Misalignment is inhibitor but not as prominent

Q51: Handling Small Risks

Question

What should you do with small risks that won't affect the project much?

A. These risks can be dismissed
B. These risks can be accepted
C. Added to low priority risk watch list
D. All risks must have valid documented risk response

Q51: Explanation

Correct Answer: C

Low-impact, low-probability risks can be added to the low priority risk watch list.

Option Analysis

- **A - Incorrect:** Risks are not dismissed; they are documented
- **B - Incorrect:** They may be accepted but should be documented on watch list
- **C - Correct:** Watch list for future monitoring
- **D - Incorrect:** Not every risk demands a response

Q52: Intrusion Detection System Type

Question

What type of control is an intrusion detection system (IDS)?

A. Detective
B. Corrective
C. Preventative
D. Recovery

Q52: Explanation

Correct Answer: A

IDS detects and gives warning when policy violation occurs; it is a detective control.

Option Analysis

- **A - Correct:** IDS detects and alerts
- **B - Incorrect:** Corrective reduces impact after detection
- **C - Incorrect:** Preventive would stop before occurrence
- **D - Incorrect:** Recovery overcomes impact on business

Q53: Audit and Accountability Functions

Question

What are functions of audit and accountability control? (Choose three)

- A Provides details on how to protect audit logs
- B Implement effective access control
- C Implement an effective audit program
- D Provides details on how to determine what to audit

Q53: Explanation

Correct Answer: A, C, D

Audit and accountability helps: implement audit program, determine what to audit, protect audit logs, non-repudiation.

Option Analysis

- **A - Correct:** Protects audit logs
- **B - Incorrect:** Access control is separate family
- **C - Correct:** Implements audit program
- **D - Correct:** Determines what to audit

Q54: Trigger for Risk Response

Question

Which acts as a trigger for risk response process?

A. Risk level increases above risk appetite
B. Risk level increases above risk tolerance
C. Risk level equates risk appetite
D. Risk level equates risk tolerance

Q54: Explanation

Correct Answer: B

Risk response process is triggered when a risk exceeds the enterprise's risk tolerance level.

Option Analysis

- **A - Incorrect:** Appetite is not the trigger
- **B - Correct:** Tolerance exceeded = trigger
- **C - Incorrect:** Equating appetite is not trigger
- **D - Incorrect:** Equating tolerance is not trigger

Q55: Complete Asset Loss

Question

What is the value of exposure factor if the asset is lost completely?

A. 1
B. Infinity
C. 10
D. 0

Q55: Explanation

Correct Answer: A

Exposure Factor = 1.0 when asset is completely lost (100% loss).

Option Analysis

- **A - Correct:** 1.0 = 100% loss
- **B - Incorrect:** Infinity is not used
- **C - Incorrect:** 10 is not valid
- **D - Incorrect:** 0 = 0% loss

Q55: Complete Asset Loss

Question

What is the value of exposure factor if the asset is lost completely?

A. 1
B. Infinity
C. 10
D. 0

Q55: Key Concept

Exposure Factor (EF)

Exposure Factor represents the percentage of an asset's value lost as a result of a single risk event.

$$EF = \frac{\text{Loss Amount}}{\text{Asset Value}}$$

- EF ranges from 0 to 1
- 0 = No loss (0%)
- 0.5 = Partial loss (50%)
- 1 = Complete loss (100%)

Q55: Relationship to SLE

Single Loss Expectancy (SLE)

Exposure Factor is used to calculate Single Loss Expectancy.

$$SLE = AV \times EF$$

where:

- AV = Asset Value
- EF = Exposure Factor
- SLE = Expected loss from one occurrence

Q55: Example

Example

A server worth $100,000 is completely destroyed by fire.

$$AV = \$100{,}000$$

$$EF = 1.0$$

$$SLE = \$100{,}000 \times 1.0$$

$$SLE = \$100{,}000$$

Since the entire asset is lost, the Exposure Factor is 1 (100%).

Q55: Option Analysis

Correct Answer: A

Exposure Factor equals 1.0 when an asset suffers a complete loss (100% impact).

- **A - Correct:** EF = 1 means 100% of asset value is lost.
- **B - Incorrect:** EF cannot be infinite; it is expressed as a percentage from 0 to 1.
- **C - Incorrect:** 10 would imply 1000% loss, which is impossible for a single asset.
- **D - Incorrect:** EF = 0 means no loss occurred.

Q55: Exam Tip

Remember

If the asset is completely destroyed, stolen, or rendered unusable, Exposure Factor = 1.0 (100%). If half the value is lost, Exposure Factor = 0.5 (50%).

Q56: Positive Risk

Question

Discovering a profitable byproduct from your project is an example of what risk response?

A. Enhancing
B. Positive
C. Opportunistic
D. Exploiting

Q56: Explanation

Correct Answer: D

This is exploiting a positive risk - a byproduct is an excellent example of exploiting an opportunity.

Option Analysis

- **A - Incorrect:** Enhancing increases probability, not seizing
- **B - Incorrect:** Positive describes risk type, not response
- **C - Incorrect:** Opportunistic is not a valid risk response
- **D - Correct:** Exploiting seizes the opportunity

Q57: ALE Formula

Question

Which is true for SLE, ARO, and ALE?

A. $\text{ALE} = \text{ARO} \,/\, \text{SLE}$

B. $\text{ARO} = \text{SLE} \,/\, \text{ALE}$

C. $\text{ARO} = \text{ALE} \times \text{SLE}$

D. $\text{ALE} = \text{ARO} \times \text{SLE}$

Q57: Explanation

Correct Answer: D

$\text{ALE} = \text{SLE} \times \text{ARO}$

Option Analysis

- **A - Incorrect:** Wrong formula
- **B - Incorrect:** Wrong formula
- **C - Incorrect:** Wrong formula
- **D - Correct:** $\text{ALE} = \text{ARO} \times \text{SLE}$

Q58: Maturity Level 3 Statements

Question

Which statements are true for risk management capability maturity level 3?

- A Workflow tools used to accelerate risk issues
- B Business knows IT fits in enterprise risk universe
- C Formal continuous improvement required
- D Risk viewed as business issue

Q58: Explanation

Correct Answer: A, B, D

Level 3: risk viewed as business issue, business knows IT fits in risk universe, workflow tools used.

Option Analysis

- **A - True:** Workflow tools used in Level 3
- **B - True:** IT fits in risk universe at Level 3
- **C - Not True:** This is Level 5
- **D - True:** Risk viewed as business issue at Level 3

Q58: Maturity Level 3 Statements

Question

Which statements are true for risk management capability maturity level 3?

- A Workflow tools used to accelerate risk issues
- B Business knows IT fits in enterprise risk universe
- C Formal continuous improvement required
- D Risk viewed as business issue

Q58: Correct Answer

Answer

A, B and D

- Risk is viewed as a business issue
- IT risk is integrated into enterprise risk management
- Workflow and management tools are used
- Processes are defined and established

Q58: Option Analysis

- **A - True**
  - Level 3 organizations use workflow tools and defined processes.
  - Risk activities become more structured and repeatable.
- **B - True**
  - The business understands that IT risk is part of the overall enterprise risk universe.
  - Risk management is no longer viewed solely as an IT responsibility.
- **C - False**
  - Formal continuous improvement is a characteristic of Level 5 (Optimized).
  - Level 5 focuses on ongoing measurement, optimization, and continuous enhancement.
- **D - True**
  - Risk is recognized as a business issue rather than merely a technical issue.
  - Management participates in risk-related decisions.

Q58: Summary Question

Exam Tip

What is the BEST description of Maturity Level 3?

- Risk is viewed as a business issue.
- IT risk is integrated into enterprise risk management.
- Defined processes and workflow tools are used.
- Formal continuous improvement has NOT yet been reached.

Q58: Maturity Level Comparison

Quick Memory Aid

- Level 1: Ad Hoc
- Level 2: Repeatable
- Level 3: Defined and Integrated
- Level 4: Managed and Measured
- Level 5: Optimized and Continuously Improved

If you see "continuous improvement," think Level 5, not Level 3.

Q59: Analyzing Risks Responsibility

Question

Which role carrier is accounted for analyzing risks, maintaining risk profile, and risk-aware decisions?

A. Business management
B. Business process owner
C. Chief information officer
D. Chief risk officer

Q59: Explanation

Correct Answer: A

Business management is accountable for analyzing risks, maintaining risk profile, and risk-aware decisions.

Option Analysis

- **A - Correct:** Business management accountable
- **B - Incorrect:** Process owner responsible but not accountable
- **C - Incorrect:** CIO has some responsibility but not accountability
- **D - Incorrect:** CRO has oversight, not direct accountability

Q59: Analyzing Risks Responsibility

Question

Which role carrier is accountable for analyzing risks, maintaining the risk profile, and making risk-aware decisions?

- (A) Business management Business process owner Chief information officer (CIO) Chief risk officer (CRO)

Q59: Correct Answer

Answer: A

Business management is accountable for analyzing risks, maintaining the risk profile, and ensuring risk-aware business decisions are made.

- Owns business objectives Owns business risk Accepts or rejects risk Makes risk-informed decisions

Q59: Option Analysis

- **A - Correct**
  - Business management is ultimately accountable for risk management activities.
  - Maintains the enterprise or business-unit risk profile.
  - Makes risk-aware business decisions. Owns risk in support of business objectives.
- **B - Incorrect**
  - Business process owners help identify, monitor, and manage risks within their processes. They are typically responsible for executing controls and reporting risks. They support risk management but are not the primary accountable party for the overall risk profile.
- **C - Incorrect**
  - The CIO is responsible for IT operations, technology strategy, and IT resources. The CIO provides risk information and supports risk management efforts. Accountability for business risk remains with business management.
- **D - Incorrect**
  - The CRO provides oversight, guidance, governance, and coordination of enterprise risk management activities. The CRO facilitates and

Q59: Exam Trap

Common CRISC Trap

Students often select the CRO because the title contains the word "Risk." However, in governance and risk management, **business management owns the risk**, while the CRO provides oversight and coordination.

Q59: RACI Perspective

Who Does What?

- Business Management = **Accountable**
- Process Owner = Responsible CIO = Support / Consulted CRO = Oversight / Governance

Q59: Summary Question

Remember for the Exam

Who ultimately owns risk and makes risk-aware business decisions?

1. Business Management **(Correct)**
2. Process Owners execute controls CIO manages technology CRO oversees risk program

Ownership of risk always stays with the business.

Q60: Poor Password and Unsafe Transmission

Question

Choosing poor password and transmitting data unprotected refers to?

A. Probabilities
B. Threats
C. Vulnerabilities
D. Impacts

Q60: Explanation

Correct Answer: C

Vulnerabilities are characteristics that may be exploited by a threat. Poor password and unprotected transmission are vulnerabilities.

Option Analysis

- **A - Incorrect:** Probability is likelihood of occurrence
- **B - Incorrect:** Threat is potential cause of harm
- **C - Correct:** Vulnerabilities are weaknesses
- **D - Incorrect:** Impact is result of exploitation

Q61: Ensuring Outsourced Compliance

Question

Which is BEST way to ensure outsourced service providers comply with security policy?

- A Penetration testing
- B Service level monitoring
- C Security awareness training
- D Periodic audits

Q61: Explanation

Correct Answer: D

Periodic audits can spot gaps in information security compliance.

Option Analysis

- **A - Incorrect:** Penetration testing identifies vulnerability, not compliance
- **B - Incorrect:** Service monitoring identifies operational issues
- **C - Incorrect:** Training increases awareness but less effective
- **D - Correct:** Periodic audits ensure compliance

Q61: Ensuring Outsourced Compliance

Question

Which is the BEST way to ensure outsourced service providers comply with organizational security policies?

- A Penetration testing
- B Service level monitoring
- C Security awareness training
- D Periodic audits

Q61: Correct Answer

Answer: D

Periodic audits are the BEST way to verify that outsourced service providers are complying with security policies, contractual requirements, and regulatory obligations.

Q61: Option Analysis

A - Penetration Testing (Incorrect)

- Identifies technical vulnerabilities and security weaknesses.
- Helps determine whether systems can be exploited.
- Does not provide comprehensive evidence that policies, procedures, and contractual security requirements are being followed.

B - Service Level Monitoring (Incorrect)

- Measures service performance against SLAs.
- Focuses on availability, response time, and service quality.
- A provider can meet SLA targets while still failing to comply with security requirements.

Q61: Option Analysis (Continued)

C - Security Awareness Training (Incorrect)

- Improves employee understanding of security practices.
- Helps reduce human error.
- Training alone does not verify that security policies are actually being followed.

D - Periodic Audits (Correct)

- Independently verifies compliance with security policies.
- Reviews controls, procedures, evidence, and records.
- Identifies compliance gaps and control weaknesses.
- Provides assurance that contractual security requirements are being met.

Q61: Exam Trap

Common CRISC Exam Trap

Students often choose Penetration Testing because it sounds security-focused. However, the question asks about **compliance with security policy**, not technical vulnerabilities. Audits verify compliance. Penetration tests verify security weaknesses.

Q61: Key Words

Match the Activity to the Objective

- Vulnerabilities → Penetration Testing
- Service Performance → SLA Monitoring
- Employee Knowledge → Awareness Training
- Compliance Verification → Periodic Audits

Q61: Summary Question

Remember for the Exam

What is the BEST method for verifying that a third-party service provider follows security policies?

1. Penetration tests find weaknesses
2. SLA monitoring tracks performance
3. Training improves awareness
4. Periodic audits verify compliance **(Correct)**

When the question asks "ensure" or "verify compliance," think AUDIT first.

Q62: Risk Prioritization Category

Question

Re-architecting existing system due to complexity - which risk prioritization option?

A. Deferrals
B. Quick win
C. Business case to be made
D. Contagious risk

Q62: Explanation

Correct Answer: C

This is categorized as business case to be made because the response requires quite large investment.

Option Analysis

- **A - Incorrect:** Deferrals address costly response to low risk
- **B - Incorrect:** Quick win requires small investment
- **C - Correct:** Large investment = business case to be made
- **D - Incorrect:** Contagious risk is a type of risk, not prioritization

Q62: Risk Prioritization Category

Question

Re-architecting an existing system due to complexity would most likely fall into which risk prioritization category?

A. Deferrals
B. Quick win
C. Business case to be made
D. Contagious risk

Q62: Correct Answer

Answer: C

Re-architecting a complex system usually requires significant funding, resources, planning, and management approval. Therefore, it falls under **Business Case to be Made**.

Q62: Option Analysis

A - Deferrals (Incorrect)

- Deferrals are risk responses that are postponed.
- Typically used when the cost of remediation exceeds the immediate benefit.
- Usually associated with lower-priority risks or budget constraints.
- Re-architecting a system is an active mitigation strategy, not merely a postponement.

B - Quick Win (Incorrect)

- Quick wins provide high benefit with relatively low cost and effort.
- Can often be implemented rapidly.
- Re-architecting an entire system is normally expensive, time consuming, and resource intensive.

Q62: Option Analysis (Continued)

C - Business Case to be Made (Correct)

- Requires substantial investment.
- Needs management approval and justification.
- Benefits must be weighed against implementation costs.
- Major architectural redesigns typically fall into this category.
- A formal business case is often required before proceeding.

D - Contagious Risk (Incorrect)

- Refers to a risk that can spread to other processes, systems, or business areas.
- It describes a type of risk, not a prioritization category for risk response initiatives.
- The question asks how the response should be prioritized, not the nature of the risk itself.

Q62: Exam Trap

Common CRISC Trap

Students often select **Quick Win** because solving complexity sounds beneficial. However, the keyword is **Re-architecting**. Re-architecting usually involves significant redesign, cost, effort, and planning. That points to **Business Case to be Made**.

Q62: Summary of Prioritization Categories

- **Quick Win**
  - Low effort
  - Low cost
  - High benefit
- **Business Case to be Made**
  - High cost
  - High effort
  - Requires approval and justification
- **Deferral**
  - Postpone action
  - Lower priority or insufficient resources
- **Contagious Risk**
  - Risk spreads across systems or processes
  - Not a prioritization category

Q62: Summary Question

Remember for the Exam

What category best describes a risk response that requires major funding, extensive planning, and management approval?

1. Deferral
2. Quick Win
3. Business Case to be Made **(Correct)**
4. Contagious Risk

Large investment + major project = Business Case to be Made

Q63: Ensuring Firewall Compliance

Question

What BEST ensures firewall configured in compliance with security policy?

- A Interview the firewall administrator
- B Review the actual procedures
- C Review device's log file
- D Review the parameter settings

Q63: Explanation

Correct Answer: D

Review of parameter settings provides basis for comparison of actual configuration to security policy.

Option Analysis

- **A - Incorrect:** Interview provides overview, not confirmation
- **B - Incorrect:** Procedures show how it should be managed, not compliance
- **C - Incorrect:** Log review shows logging is enabled, not configuration
- **D - Correct:** Parameter settings show actual configuration

Q64: NOT Used for CSF Measurement

Question

Which is NOT used for measurement of Critical Success Factors?

A. Productivity
B. Quality
C. Quantity
D. Customer service

Q64: Explanation

Correct Answer: C

Quantity is NOT used for measuring Critical Success Factors.

Option Analysis

- **A - Incorrect:** Productivity is used
- **B - Incorrect:** Quality is used
- **C - Correct:** Quantity is not used
- **D - Incorrect:** Customer service is used

Q65: Risk Management Plan Statement

Question

Which statement is NOT true regarding risk management plan?

- A Output of Plan Risk Management
- B Input to all remaining risk-planning
- C Includes description of risk responses and triggers
- D Includes thresholds, scoring, responsible parties, budgets

Q65: Explanation

Correct Answer: C

Risk management plan does NOT include responses to risks or triggers. Responses are in risk register.

Option Analysis

- **A - True:** Output of Plan Risk Management
- **B - True:** Input to other processes
- **C - Not True:** Responses/triggers are in risk register
- **D - True:** Includes thresholds, scoring, parties, budgets

Q66: Choosing Risk Response Tool

Question

Which tool would you use to choose appropriate risk response?

- A Project network diagrams
- B Cause-and-effect analysis
- C Decision tree analysis
- D Delphi Technique

Q66: Explanation

Correct Answer: C

Decision tree analysis helps determine best risk response by measuring probability, impact, and risk exposure.

Option Analysis

- **A - Incorrect:** Network diagrams visualize workflow
- **B - Incorrect:** Cause-effect exposes risk factors
- **C - Correct:** Decision tree evaluates response options
- **D - Incorrect:** Delphi identifies most probable risks

Q66: Choosing Risk Response Tool

Question

Which tool would you use to choose the most appropriate risk response?

A. Project network diagrams
B. Cause-and-effect analysis
C. Decision tree analysis
D. Delphi Technique

Q66: Correct Answer

Answer: C

Decision Tree Analysis helps determine the best risk response by evaluating alternative actions based on probability, impact, expected outcomes, and risk exposure.

Q66: Option Analysis

A - Project Network Diagrams (Incorrect)

- Used for project scheduling and activity dependencies.
- Shows task sequence and critical paths.
- Helps identify schedule risks.
- Does not determine which risk response option should be selected.

B - Cause-and-Effect Analysis (Incorrect)

- Also known as a Fishbone or Ishikawa Diagram.
- Used to identify root causes of problems and risks.
- Helps understand why a risk exists.
- Does not evaluate competing response options.

Q66: Option Analysis (Continued)

C - Decision Tree Analysis (Correct)

- Compares multiple response alternatives.
- Evaluates probabilities and possible outcomes.
- Measures expected gain or loss for each choice.
- Helps select the most appropriate risk treatment option.
- Frequently used when several response strategies are available.

D - Delphi Technique (Incorrect)

- Structured method of obtaining expert opinions.
- Often used to identify and assess risks.
- Experts provide input anonymously.
- Useful for forecasting and risk identification.
- Does not directly determine the optimal risk response.

Q66: Example

Decision Tree Example

A company must choose between:

- Implementing a new security control
- Purchasing cyber insurance
- Accepting the risk

Decision tree analysis compares the costs, probabilities, and expected outcomes of each option to identify the best response.

Q66: Exam Trap

Common CRISC Trap

Students often choose Cause-and-Effect Analysis because it involves risk analysis. However, Cause-and-Effect Analysis identifies **why a risk exists**. The question asks which tool helps choose a **risk response**. That points to **Decision Tree Analysis**.

Q66: Summary of Tools

- Network Diagram = Schedule and Dependencies
- Cause-and-Effect = Root Cause Analysis
- Decision Tree = Choose Best Response
- Delphi Technique = Gather Expert Opinion

Q66: Summary Question

Remember for the Exam

Which tool helps management compare alternative actions and select the best risk response?

1. Network Diagram
2. Cause-and-Effect Analysis
3. Decision Tree Analysis **(Correct)**
4. Delphi Technique

If the question asks "choose among alternatives," think Decision Tree.

Q67: Risk Management Maturity Level

Question

Enterprise takes decisions without risk credential information - which maturity level?

- A Level 1
- B Level 0
- C Level 5
- D Level 4

Q67: Explanation

Correct Answer: B

Level 0: enterprise does not recognize need to consider risk management, decisions lack credible information.

Option Analysis

- **A - Incorrect:** Level 1 uses credible information
- **B - Correct:** Level 0 lacks risk awareness and information
- **C - Incorrect:** Level 5 has full automation
- **D - Incorrect:** Level 4 integrates with ERM

Q68: Data Owner Priority

Question

Which is priority of data owners when establishing risk mitigation method?

A. User entitlement changes
B. Platform security
C. Intrusion detection
D. Antivirus controls

Q68: Explanation

Correct Answer: A

Data owners are responsible for assigning user entitlement changes and approving access to systems.

Option Analysis

- **A - Correct:** User entitlement changes = data owner responsibility
- **B - Incorrect:** Platform security = data custodian
- **C - Incorrect:** Intrusion detection = data custodian
- **D - Incorrect:** Antivirus controls = data custodian

Q68: Data Owner Priority

Question

Which is the priority responsibility of a data owner when establishing a risk mitigation method?

A. User entitlement changes
B. Platform security
C. Intrusion detection
D. Antivirus controls

Q68: Correct Answer

Answer: A

Data owners are responsible for determining who should have access to information and approving or removing user access rights. Therefore, user entitlement changes are the primary concern of the data owner.

Q68: Option Analysis

A - User Entitlement Changes (Correct)

- Data owners determine access requirements.
- Approve user access rights.
- Review and remove inappropriate access.
- Ensure least privilege and segregation of duties.
- Directly supports protection of sensitive data.

B - Platform Security (Incorrect)

- Includes server, operating system, and infrastructure protection.
- Typically managed by system administrators, security teams, or data custodians.
- Data owners define requirements but do not administer platform security.

Q68: Option Analysis (Continued)

C - Intrusion Detection (Incorrect)

- Detects unauthorized access attempts.
- Usually managed by information security teams and security operations centers.
- It is a technical control rather than a data owner responsibility.

D - Antivirus Controls (Incorrect)

- Protects systems against malware.
- Implemented and monitored by IT operations and security administrators.
- Falls under custodial and operational security responsibilities.

Q68: Data Owner vs Data Custodian

Key Difference

Data Owner

- Classifies data
- Approves access
- Reviews entitlements
- Determines protection requirements

Data Custodian

- Implements controls
- Maintains systems
- Manages security tools
- Operates technical safeguards

Q68: Exam Trap

Common CRISC Trap

Students often choose Platform Security or Intrusion Detection because they sound more security-focused. However, the question asks about the **data owner's responsibility**. Data owners control **who gets access to data**, while custodians control **how systems are secured**.

Q68: Summary Question

Remember for the Exam

What is the MOST important responsibility of a data owner?

1. Approve and review user access **(Correct)**
2. Configure operating systems
3. Monitor intrusion detection systems
4. Manage antivirus software

Data Owner = Owns the Data and Access Rights.

Q69: Forbidding Personal Email Use

Question

What policy forbids employees from using organizational e-mail for personal use?

A. Anti-harassment policy
B. Acceptable use policy
C. Intellectual property policy
D. Privacy policy

Q69: Explanation

Correct Answer: B

Acceptable Use Policy (AUP) restricts ways network, website or system may be used.

Option Analysis

- **A** - **Incorrect:** Anti-harassment is not IS security
- **B** - **Correct:** AUP defines acceptable system usage
- **C** - **Incorrect:** Intellectual property is not personal email
- **D** - **Incorrect:** Privacy policy is about data handling

Q70: Risk Response Identification

Question

Wendy reduces risk impact from $75,000 to $15,000 with 10% chance, costing $25,000. What risk response?

A. Mitigation
B. Avoidance
C. Transference
D. Enhancing

Q70: Explanation

Correct Answer: A

Mitigation implies reduction in probability and/or impact of adverse risk event within acceptable thresholds.

Option Analysis

- **A - Correct:** Reduction of impact and probability
- **B - Incorrect:** Avoidance changes plan to avoid entirely
- **C - Incorrect:** Transference shifts to third party
- **D - Incorrect:** Enhancing is for positive risks

Q71: Risk

Question

Which process addresses risks by priorities, schedules PM plan as required, inserts resources into budget?

A. Monitor and Control Risk
B. Plan risk response
C. Identify Risks
D. Qualitative Risk Analysis

Q71: Explanation

Correct Answer: B

Plan Risk Response addresses risks by priorities, schedules PM plan, and inserts resources and activities into budget.

Option Analysis

- **A - Incorrect:** Monitor and Control implements responses
- **B - Correct:** Plan Risk Response prioritizes and schedules
- **C - Incorrect:** Identify Risks determines risks
- **D - Incorrect:** Qualitative Analysis assesses nature of risks

Q72: Negative Risk Response

Question

Which risk response is used for negative risk events?

A. Share
B. Enhance
C. Exploit
D. Accept

Q72: Explanation

Correct Answer: D

Acceptance is used for negative risk events. Share, Enhance, Exploit are for positive risks.

Option Analysis

- **A - Incorrect:** Share is for positive risks
- **B - Incorrect:** Enhance is for positive risks
- **C - Incorrect:** Exploit is for positive risks
- **D - Correct:** Accept is for negative risks

Q72: Negative Risk Response

Question

Which risk response is used for negative risk events?

A. Share
B. Enhance
C. Exploit
D. Accept

Q72: Correct Answer

Answer: D

Acceptance is a valid response for negative risks (threats). The organization consciously decides to take no immediate action and tolerate the risk within established risk appetite and risk tolerance levels.

Q72: Understanding Risk Responses

Negative Risks (Threats)

- Avoid
- Mitigate (Reduce)
- Transfer
- Accept

Positive Risks (Opportunities)

- Exploit
- Enhance
- Share
- Accept

Accept can be used for both threats and opportunities.

Q72: Option Analysis

A - Share (Incorrect)

- Used for positive risks (opportunities).
- Involves partnering with another party to increase the chance of realizing a benefit.
- Example: Joint venture to pursue a business opportunity.

B - Enhance (Incorrect)

- Used for positive risks.
- Increases the probability or impact of a beneficial event.
- Goal is to maximize potential gain.

Q72: Option Analysis (Continued)

C - Exploit (Incorrect)

- Used for positive risks.
- Ensures an opportunity occurs and delivers maximum value.
- Organization actively pursues the beneficial outcome.

D - Accept (Correct)

- Valid response for negative risks.
- Used when the risk falls within tolerance levels.
- Used when treatment costs exceed expected benefits.
- Management knowingly retains the risk.

Q72: Exam Trap

Common CRISC Trap

Students often memorize that Share, Enhance, and Exploit are opportunity responses but forget that **Accept** can apply to both positive and negative risks. The key phrase in the question is **negative risk events (threats)**. Among the options provided, only Accept applies.

Q72: Quick Comparison

Threat vs Opportunity

- Threat + Reduce Impact = Mitigate
- Threat + Do Nothing = Accept
- Opportunity + Increase Benefit = Enhance
- Opportunity + Guarantee Benefit = Exploit
- Opportunity + Partner = Share

Q72: Summary Question

Remember for the Exam

Which of the following is a response to a negative risk (threat)?

1. Share
2. Enhance
3. Exploit
4. Accept **(Correct)**

Share, Enhance, and Exploit = Opportunities. Accept = Can be used for threats.

Q73: Investment Risk Definition

Question

Which risk refers to probability that actual return is lower than investor's expectations?

A. Integrity risk
B. Project ownership risk
C. Relevance risk
D. Expense risk

Q73: Explanation

Correct Answer: D

Expense risk is probability that actual return on investment will be lower than investor's expectations.

Option Analysis

- **A - Incorrect:** Integrity = data cannot be relied on
- **B - Incorrect:** Project ownership = lack of accountability
- **C - Incorrect:** Relevance = wrong info to wrong people
- **D - Correct:** Expense risk = lower than expected return

Q74: PRIMARY Requirements for Risk Scenarios

Question

What are PRIMARY requirements for developing risk scenarios? (Choose two)

- A Potential threats and vulnerabilities
- B Determination of value of asset at risk
- C Determination of actors
- D Determination of threat type

Q74: Explanation

Correct Answer: A and B

Primary requirements: value of asset/business process at risk, and potential threats and vulnerabilities.

Option Analysis

- **A - Correct:** Threats and vulnerabilities are primary
- **B - Correct:** Asset value is primary
- **C - Incorrect:** Actors are secondary components
- **D - Incorrect:** Threat type is secondary component

Q75: CRO Responsibilities

Question

What are responsibilities of the CRO? (Choose three)

- A Managing risk assessment process
- B Implement corrective actions
- C Advising Board of Directors
- D Managing supporting risk management function

Q75: Explanation

Correct Answer: A, B, D

CRO responsibilities: managing risk assessment, implementing corrective actions, supporting risk management functions.

Option Analysis

- **A - Correct:** Managing risk assessment process
- **B - Correct:** Implementation of corrective actions
- **C - Incorrect:** CRO advises but this is not primary responsibility listed
- **D - Correct:** Supporting risk management functions

Q76: Vendor Change Control System

Question

Which system introduces and executes stakeholder change request with vendor?

A. Contract change control system
B. Scope change control system
C. Cost change control system
D. Schedule change control system

Q76: Explanation

Correct Answer: A

Contract change control system addresses changes with vendor that may affect the project contract.

Option Analysis

- **A - Correct:** Contract change control for vendor changes
- **B - Incorrect:** Scope may change but vendor relationship is contract
- **C - Incorrect:** Cost change system manages cost changes
- **D - Incorrect:** No schedule impact indicated

Q76: Vendor Change Control System

Question

Which system is used to introduce, evaluate, approve, and execute stakeholder change requests involving a vendor?

A. Contract change control system
B. Scope change control system
C. Cost change control system
D. Schedule change control system

Q76: Correct Answer

Answer: A

The Contract Change Control System manages changes to vendor agreements, contractual obligations, deliverables, terms, and conditions. Any stakeholder-requested change affecting a vendor's contractual commitments should be processed through the contract change control system.

Q76: Option Analysis

A - Contract Change Control System (Correct)

- Manages changes involving vendors and suppliers.
- Evaluates contractual impact.
- Reviews legal obligations and deliverables.
- Ensures formal approval before modifying vendor commitments.
- Maintains compliance with procurement contracts.

B - Scope Change Control System (Incorrect)

- Controls changes to project scope and requirements.
- Focuses on what work must be performed.
- While a scope change may eventually affect a vendor, the vendor relationship itself is governed through the contract.
- The BEST answer remains Contract Change Control.

Q76: Option Analysis (Continued)

C - Cost Change Control System (Incorrect)

- Manages project budget and financial changes.
- Evaluates funding and cost impacts.
- Cost may be affected by vendor modifications, but this does not govern the vendor relationship.

D - Schedule Change Control System (Incorrect)

- Manages timeline and project schedule adjustments.
- Reviews impacts to milestones and deadlines.
- The question focuses on vendor change requests, not scheduling concerns.

Q76: Exam Trap

Common CRISC Trap

Students often select Scope Change Control because stakeholder requests frequently involve changing project requirements. However, the keyword is **vendor**. Whenever a change affects a vendor contract, supplier agreement, statement of work (SOW), or procurement relationship, think **Contract Change Control System**.

Q76: Quick Comparison

- Scope Change Control = What work changes?
- Cost Change Control = How much money changes?
- Schedule Change Control = When does work occur?
- Contract Change Control = What changes with the vendor?

Q76: Summary Question

Remember for the Exam

Which change control process should be used when a project stakeholder requests a modification that affects a vendor's contractual obligations?

1. Contract Change Control System **(Correct)**
2. Scope Change Control System
3. Cost Change Control System
4. Schedule Change Control System

Vendor + Contract = Contract Change Control System

Q77: When Control Costs Exceed Benefits

Question

Costs of specific controls exceed benefits of mitigating a given risk. What is BEST action?

A. Apply the appropriate control anyway
B. Adopt corrective control
C. Accept the risk rather than incur cost of mitigation
D. Exploit the risk

Q77: Explanation

Correct Answer: C

If control costs exceed benefits, enterprise may accept risk rather than incur cost of mitigation.

Option Analysis

- **A - Incorrect:** Controls are not applied when cost exceeds benefit
- **B - Incorrect:** No control should be adopted
- **C - Correct:** Accept risk when mitigation cost exceeds benefit
- **D - Incorrect:** Exploit is for opportunities, not negative risk

Q78: Mortality Tables Mathematics

Question

Mortality tables are based on what mathematical activity? (Choose three)

- A Normal distributions
- B Probabilities
- C Impact
- D Sampling

Q78: Explanation

Correct Answer: A, B, D

Mortality tables use: normal distributions, probabilities, and sampling. Impact is not mathematical.

Option Analysis

- **A - Correct:** Normal distributions used
- **B - Correct:** Probabilities used
- **C - Incorrect:** Impact uses words (Low/Medium/High), not mathematical
- **D - Correct:** Sampling used

Q78: Mortality Tables Mathematics

Question

Mortality tables are based on what mathematical activities? (Choose three)

- A Normal distributions
- B Probabilities
- C Impact
- D Sampling

Q78: Correct Answer

Answer: A, B, and D

Mortality tables are built using statistical and actuarial techniques, including probability theory, sampling, and statistical distributions. Impact is a risk-management concept rather than a mathematical foundation of mortality tables.

Q78: What Are Mortality Tables?

Definition

Mortality tables (life tables) estimate the probability that individuals of a particular age will survive or die during a specific time period. Insurance companies and risk professionals use these tables to estimate future events and potential losses.

Q78: Option Analysis

A - Normal Distributions (Correct)

- Statistical analysis often uses distributions to model population behavior.
- Mortality studies rely on statistical methods and distribution analysis.
- Supports prediction of future outcomes.

B - Probabilities (Correct)

- Mortality tables primarily express probabilities.
- Example:
  - Probability of death
  - Probability of survival
  - Probability of reaching a given age
- Probability theory is a fundamental component.

Q78: Option Analysis (Continued)

C - Impact (Incorrect)

- Impact measures the consequence of a risk event.
- Examples include:
  - Low
  - Medium
  - High
- Impact helps assess risk but is not a mathematical basis for constructing mortality tables.
- Mortality tables estimate likelihood, not impact.

D - Sampling (Correct)

- Mortality tables are developed from large data sets.
- Statistical sampling is used to analyze populations.
- Historical population samples provide the data used to estimate future probabilities.

Q78: Exam Trap

Common CRISC Trap

Students often select Impact because it is commonly used in risk assessments. However, the question asks about the mathematical foundations of mortality tables. Impact measures consequences of risk events, while mortality tables are based on statistics, probabilities, and sampled population data.

Q78: Quick Comparison

- Probability = Chance an event occurs
- Sampling = Collecting representative data
- Distribution = Statistical modeling
- Impact = Severity of consequences

Mortality tables estimate likelihood, not impact.

Q78: Summary Question

Remember for the Exam

Which concepts are mathematical and statistical foundations of mortality tables?

1. Normal Distributions ✓
2. Probabilities ✓
3. Impact
4. Sampling ✓

Think Statistics = Distributions + Probabilities + Sampling

Q79: Hiring Professional Vendor

Question

Harry hires professional vendor to complete dangerous portion of work. What risk response?

A. Transference
B. Mitigation
C. Acceptance
D. Avoidance

Q79: Explanation

Correct Answer: A

Risk transfer shifts impact to another entity. Risk doesn't go away but responsibility is transferred.

Option Analysis

- **A - Correct:** Transfer to professional vendor
- **B - Incorrect:** Mitigation would reduce risk in-house
- **C - Incorrect:** Acceptance would retain risk
- **D - Incorrect:** Avoidance removes risk entirely

Q: Zachman Framework Purpose

Question

What is the PRIMARY purpose of the Zachman Framework?

A. Performing risk assessments
B. Providing a structured enterprise architecture taxonomy
C. Measuring IT performance
D. Managing project schedules

Q: Zachman Framework Explanation

Correct Answer: B

The Zachman Framework provides a structured way to classify and organize enterprise architecture artifacts from multiple stakeholder perspectives.

- **A - Incorrect:** Risk assessment is not its primary purpose.
- **B - Correct:** It is an enterprise architecture taxonomy.
- **C - Incorrect:** Performance measurement is not the focus.
- **D - Incorrect:** Project scheduling is unrelated.

Q: Directed Acyclic Graph (DAG)

Question

Which characteristic BEST describes a Directed Acyclic Graph (DAG)?

- A Contains circular dependencies
- B Contains directed relationships without cycles
- C Requires a single root node
- D Supports only two branches per node

Q: DAG Explanation

Correct Answer: B

A Directed Acyclic Graph consists of directed connections and does not permit cycles or loops.

- **A - Incorrect:** Cycles are not allowed.
- **B - Correct:** Directed relationships with no loops.
- **C - Incorrect:** A root node is not mandatory.
- **D - Incorrect:** No such limitation exists.

Q: Federal Enterprise Architecture

Question

What is the PRIMARY objective of the Federal Enterprise Architecture (FEA)?

A. Improve alignment between business and technology

B. Eliminate all security risks

C. Replace project management methodologies

D. Define audit procedures

Q: FEA Explanation

Correct Answer: A

FEA promotes alignment between business functions, information, applications, and technology.

- **A - Correct:** Supports business-IT alignment.
- **B - Incorrect:** No framework removes all risks.
- **C - Incorrect:** FEA is not a project methodology.
- **D - Incorrect:** Audit procedures are outside its scope.

Q: SABSA Security Architecture

Question

SABSA is BEST described as:

- A. A software development framework
- B. A business-driven security architecture framework
- C. A project scheduling methodology
- D. A database design standard

Q: SABSA Explanation

Correct Answer: B

SABSA is a business-driven framework used to develop risk-focused enterprise security architectures.

- **A - Incorrect:** Not a software development framework.
- **B - Correct:** Aligns security architecture with business requirements.
- **C - Incorrect:** Not used for scheduling.
- **D - Incorrect:** Not a database design standard.

Q80: Why Project Team in Risk Identification

Question

Why should project team members be involved in Identify Risk process?

A. They will most likely cause risk events
B. They will have best responses
C. They are most affected
D. They will need sense of ownership and responsibility

Q80: Explanation

Correct Answer: D

Project team develops sense of ownership and responsibility for risk events and associated responses.

Option Analysis

- **A - Incorrect:** Not the primary reason
- **B - Incorrect:** Not the primary reason
- **C - Incorrect:** Not the primary reason
- **D - Correct:** Ownership and responsibility

Q81: Risk Monitoring Requirements

Question

What are requirements of monitoring risk? (Choose three)

- A Information of various stakeholders
- B Preparation of detailed monitoring plan
- C Identifying the risk to be monitored
- D Defining the project's scope

Q81: Explanation

Correct Answer: B, C, D

Requirements: identify risk to monitor, prepare detailed plan, define project scope.

Option Analysis

- **A - Incorrect:** Stakeholder info not required for monitoring
- **B - Correct:** Detailed monitoring plan
- **C - Correct:** Identify risk to monitor
- **D - Correct:** Define project scope

Q82: Insurance Risk Management Technique

Question

Liability insurance policy for security risks uses which risk management technique?

A. Risk transfer
B. Risk acceptance
C. Risk avoidance
D. Risk mitigation

Q82: Explanation

Correct Answer: A

Insurance transfers security risks from company to insurance company.

Option Analysis

- **A - Correct:** Transfer risk to insurance
- **B - Incorrect:** Acceptance retains risk
- **C - Incorrect:** Avoidance not performing activity
- **D - Incorrect:** Mitigation reduces severity/likelihood

Q83: Improving Performance Through Risk Analysis

Question

How can you improve project performance through risk analysis with stakeholders?

A. Involve subject matter experts

B. Involve stakeholders only in relevant phases

C. Use qualitative risk analysis quickly

D. Focus on high-priority risks through qualitative analysis

Q83: Explanation

Correct Answer: D

By focusing on high-priority risk events through qualitative risk analysis, you can improve project performance.

Option Analysis

- **A - Incorrect:** SMEs help but not best approach
- **B - Incorrect:** Stakeholders should be involved throughout
- **C - Incorrect:** Qualitative is fast but not best answer
- **D - Correct:** Focus on high-priority risks

Q84: When Risk Events Occur

Question

Which statement best addresses when a project risk actually happens?

A. Risks are uncertain as to when they will happen
B. Risks can happen at any time
C. Project risks are always in the future
D. Risk triggers are warning signs

Q84: Explanation

Correct Answer: C

According to PMBOK, a project risk is always in the future. If risk has happened, it's an issue.

Option Analysis

- **A - Incorrect:** Risks are uncertain but can be identified
- **B - Incorrect:** Risks only happen in the future
- **C - Correct:** Risks are always in the future
- **D - Incorrect:** This is true but not best answer

Q: Risk Register Purpose

Question

What is the PRIMARY purpose of a risk register?

- A Define project scope
- B Document identified risks and responses
- C Track project costs
- D Assign project resources

Q: Explanation

Correct Answer: B

A risk register is used to document identified risks, their characteristics, ownership, and response plans.

- **A - Incorrect:** Scope is documented in the scope baseline.
- **B - Correct:** Central repository for project risks.
- **C - Incorrect:** Costs are tracked in the budget.
- **D - Incorrect:** Resources are managed separately.

Q: Critical Path

Question

What is the critical path in a project?

- A The shortest path through the project
- B The path with the largest budget
- C The longest sequence of activities determining project duration
- D The path with the highest risk

Q: Explanation

Correct Answer: C

The critical path is the longest path through the schedule and determines the minimum project completion time.

- **A - Incorrect:** Not based on shortest duration.
- **B - Incorrect:** Budget is unrelated.
- **C - Correct:** Delays on critical path delay the project.
- **D - Incorrect:** Risk level does not define the critical path.

Q: Delphi Technique

Question

What is the PRIMARY purpose of the Delphi Technique?

- A Develop project schedules
- B Obtain expert consensus anonymously
- C Calculate project costs
- D Monitor project performance

Q: Explanation

Correct Answer: B

Delphi Technique gathers opinions from experts anonymously until consensus is reached.

- **A - Incorrect:** Not a scheduling tool.
- **B - Correct:** Used for risk identification and estimation.
- **C - Incorrect:** Not a cost-calculation method.
- **D - Incorrect:** Not a project monitoring tool.

Q: Threat Response

Question

Which is a common response strategy for a negative risk (threat)?

A. Exploit
B. Share
C. Mitigate
D. Enhance

Q: Explanation

Correct Answer: C

Mitigation reduces either the probability or impact of a threat.

- **A - Incorrect:** Exploit is for opportunities.
- **B - Incorrect:** Share is for opportunities.
- **C - Correct:** Mitigate is a threat response.
- **D - Incorrect:** Enhance is for opportunities.

Q: WBS Purpose

Question

What is the PRIMARY purpose of a Work Breakdown Structure (WBS)?

- A Break project work into manageable components
- B Assign risks to stakeholders
- C Determine project budget
- D Measure project quality

Q: Explanation

Correct Answer: A

The WBS decomposes project scope into smaller, manageable work packages.

- **A - Correct:** Foundation for planning and estimating.
- **B - Incorrect:** Risk assignment is separate.
- **C - Incorrect:** Budgeting comes later.
- **D - Incorrect:** Quality management is separate.

Q85: Indication of High Risk Level

Question

Which is MOST effective method for indicating risk level approaching unacceptable level?

A. Risk register
B. Cause and effect diagram
C. Risk indicator
D. Return on investment

Q85: Explanation

Correct Answer: C

Risk indicators are metrics used to indicate risk thresholds - when risk level is approaching high level.

Option Analysis

- **A - Incorrect:** Register is inventory, not indicator
- **B - Incorrect:** Cause-effect identifies root causes
- **C - Correct:** Risk indicators show thresholds
- **D - Incorrect:** ROI is performance measure

Q86: Risk Information Sharing

Question

Which plan defines who will be available to share information on project risks?

A. Risk Management Plan
B. Stakeholder management strategy
C. Communications Management Plan
D. Resource Management Plan

Q86: Explanation

Correct Answer: C

Communications Management Plan defines who will be available to share information on risks and responses.

Option Analysis

- **A - Incorrect:** Risk plan defines identification/analysis
- **B - Incorrect:** Stakeholder strategy doesn't address
- **C - Correct:** Communications Plan defines roles
- **D - Incorrect:** Resource plan doesn't define risk communications

Q87: Anonymous Risk Identification

Question

Which method allows participants to anonymously identify risk events?

A. Delphi technique
B. Root cause analysis
C. Isolated pilot groups
D. SWOT analysis

Q87: Explanation

Correct Answer: A

Delphi technique uses rounds of anonymous surveys to build consensus and prevents individuals from influencing others.

Option Analysis

- **A - Correct:** Anonymous Delphi technique
- **B - Incorrect:** Root cause is not anonymous
- **C - Incorrect:** Isolated pilot groups is not valid
- **D - Incorrect:** SWOT is not anonymous

Q88: Lack of Adequate Controls

Question

Which represents lack of adequate controls?

A. Vulnerability
B. Threat
C. Asset
D. Impact

Q88: Explanation

Correct Answer: A

Vulnerability is a weakness or lack of safeguard that can be exploited by a threat.

Option Analysis

- **A - Correct:** Vulnerability = lack of adequate controls
- **B - Incorrect:** Threat is potential cause
- **C - Incorrect:** Asset is economic resource
- **D - Incorrect:** Impact is financial loss measure

Q89: NOT in Risk Register Update

Question

Which is NOT included in risk register updates from qualitative risk analysis?

A. Trends in qualitative risk analysis
B. Risk probability-impact matrix
C. Risks grouped by categories
D. Watchlist of low-priority risks

Q89: Explanation

Correct Answer: B

Risk probability-impact matrix is NOT included in risk register updates. The matrix is a tool.

Option Analysis

- **A - Incorrect:** Trends are included
- **B - Correct:** Matrix is not included
- **C - Incorrect:** Categories are included
- **D - Incorrect:** Watchlist is included

Q90: XXXX Risk

Question

Risk that happens with important business partner and affects large group of enterprises?

A. Contagious risk
B. Reporting risk
C. Operational risk
D. Systemic risk

Q90: Explanation

Correct Answer: D

Systemic risks happen with important business partner and affect large group of enterprises within an area or industry.

Option Analysis

- **A - Incorrect:** Contagious = risk events with several partners
- **B - Incorrect:** Reporting = bad decisions from wrong reporting
- **C - Incorrect:** Operational = day-to-day operations risk
- **D - Correct:** Systemic = large group affected

Q91: Risk Prioritization Tool

Question

What do you need next to prioritize risks after calculating probability and impact?

A. Affinity Diagram
B. Risk rating rules
C. Project Network Diagram
D. Risk categories

Q91: Explanation

Correct Answer: B

Risk rating rules define how to prioritize risks after probability and impact values are calculated.

Option Analysis

- **A - Incorrect:** Affinity sorts ideas
- **B - Correct:** Risk rating rules prioritize
- **C - Incorrect:** Network shows sequencing
- **D - Incorrect:** Categories are output, not tool

Q92: Change Request Immediate Action

Question

Customer requests change in existing project plan. What is your immediate action?

A. Update risk register
B. Ask for formal change request
C. Ignore request
D. Refuse change request

Q92: Explanation

Correct Answer: B

Whenever customer requests change, ask for formal change request.

Option Analysis

- **A - Incorrect:** First action is formal change request
- **B - Correct:** Require formal change request
- **C - Incorrect:** Cannot ignore
- **D - Incorrect:** Cannot refuse without analysis

Q93: Certainty Equivalent Value

Question

"Expected guaranteed value of taking a risk" describes what?

A. Certainty equivalent value
B. Risk premium
C. Risk value guarantee
D. Certain value assurance

Q93: Explanation

Correct Answer: A

Certainty equivalent value is the expected guaranteed value of taking a risk.

Option Analysis

- **A - Correct:** Certainty equivalent value
- **B - Incorrect:** Risk premium is difference between expected value and certainty equivalent
- **C - Incorrect:** Not a valid term
- **D - Incorrect:** Not a valid term

Q94: Risk Trigger

Question

Hardware vendor calls saying delivery won't arrive on time. What is this?

A. Residual risk
B. Trigger
C. Contingency plan
D. Secondary risk

Q94: Explanation

Correct Answer: B

Triggers are warning signs of upcoming risk event. Delay in delivery is a trigger.

Option Analysis

- **A - Incorrect:** Residual remains after applying controls
- **B - Correct:** Trigger is warning sign
- **C - Incorrect:** No contingency plan mentioned
- **D - Incorrect:** Secondary from implementing response

Q95: NOT an Input to Quantitative Analysis

Question

Which is NOT an input to quantitative risk analysis process?

- A Risk management plan
- B Enterprise environmental factors
- C Cost management plan
- D Risk register

Q95: Explanation

Correct Answer: B

Enterprise environmental factors is NOT an input to quantitative risk analysis.

Option Analysis

- **A - Incorrect:** Risk management plan is input
- **B - Correct:** EEF is not an input
- **C - Incorrect:** Cost management plan is input
- **D - Incorrect:** Risk register is input

Q96: Low Probability and Impact Risks

Question

What should Stephen do with 47 risks that have low probability and low impact?

A. Accept the risks
B. Add to watchlist for future monitoring
C. Dismiss the risks
D. Add to risk register

Q96: Explanation

Correct Answer: B

Low probability and low impact risks should be added to a watchlist for future monitoring.

Option Analysis

- **A - Incorrect:** They may be accepted but best is watchlist
- **B - Correct:** Watchlist for future monitoring
- **C - Incorrect:** Risks are not dismissed
- **D - Incorrect:** Best is watchlist first

Q97: Newly Identified Risks

Question

Jenny uncovers several risk events during quantitative risk analysis. What should she do?

A. Enter into qualitative analysis
B. Determine if accepted or responded to
C. Enter into risk register
D. Continue with quantitative analysis

Q97: Explanation

Correct Answer: C

All identified risk events should be entered into the risk register.

Option Analysis

- **A - Incorrect:** Document first
- **B - Incorrect:** Document and analyze
- **C - Correct:** Enter in risk register
- **D - Incorrect:** Need identification first

Q98: Not Engaging in Activity

Question

Enterprise chooses not to engage in e-commerce. What risk form is this?

- A Risk avoidance
- B Risk treatment
- C Risk acceptance
- D Risk transfer

Q98: Explanation

Correct Answer: A

Not engaging in any activity avoids the inherent risk associated with the activity.

Option Analysis

- **A - Correct:** Avoidance = not performing activity
- **B - Incorrect:** Treatment = reducing frequency/impact
- **C - Incorrect:** Acceptance = informed decision to accept
- **D - Incorrect:** Transfer = sharing with another party

Q99: COSO ERM Risk Components

Question

Which are risk components of COSO ERM framework? (Choose three)

- A Risk response
- B Internal environment
- C Business continuity
- D Control activities

Q99: Explanation

Correct Answer: A, B, D

COSO ERM components: internal environment, objective settings, event identification, risk assessment, risk response, control activities, information/communication, monitoring.

Option Analysis

- **A - Correct:** Risk response is component
- **B - Correct:** Internal environment is component
- **C - Incorrect:** Business continuity is NOT component
- **D - Correct:** Control activities is component

Q100: COBIT Governance Components

Question

Which are components of the COBIT governance system? (Choose three)

- A Processes
- B Organizational structures
- C Disaster recovery plan
- D Culture, ethics and behavior

Q100: Explanation

Correct Answer: A, B, D

COBIT governance system components include processes, organizational structures, culture/ethics/behavior, information, policies, people and services.

- **A - Correct:** Processes are a COBIT component.
- **B - Correct:** Organizational structures are included.
- **C - Incorrect:** Disaster recovery is not a governance component.
- **D - Correct:** Culture, ethics and behavior are components.

Q101: COSO Internal Control

Question

Which are components of the COSO Internal Control Framework? (Choose three)

- A Control Environment
- B Monitoring Activities
- C Vulnerability Assessment
- D Control Activities

Q101: Explanation

Correct Answer: A, B, D

COSO Internal Control consists of Control Environment, Risk Assessment, Control Activities, Information and Communication, and Monitoring Activities.

- **A - Correct:** Core COSO component.
- **B - Correct:** Core COSO component.
- **C - Incorrect:** Vulnerability assessment is not a COSO component.
- **D - Correct:** Core COSO component.

Q102: SABSA Layers

Question

Which are layers of the SABSA framework? (Choose three)

- A Contextual
- B Conceptual
- C Recovery
- D Logical

Q102: Explanation

Correct Answer: A, B, D

SABSA layers include Contextual, Conceptual, Logical, Physical, Component and Operational.

- **A - Correct:** Contextual layer.
- **B - Correct:** Conceptual layer.
- **C - Incorrect:** Recovery is not a SABSA layer.
- **D - Correct:** Logical layer.

Q103: Zachman Perspectives

Question

Which are perspectives within the Zachman Framework? (Choose three)

- A Planner
- B Owner
- C Incident Manager
- D Designer

Q103: Explanation

Correct Answer: A, B, D

Zachman perspectives include Planner, Owner, Designer, Builder, Subcontractor and Functioning Enterprise.

- **A - Correct:** Planner perspective.
- **B - Correct:** Owner perspective.
- **C - Incorrect:** Incident Manager is not a Zachman perspective.
- **D - Correct:** Designer perspective.

Q104: FAIR Risk Analysis

Question

Which are core elements of the FAIR model? (Choose three)

- A Threat Event Frequency
- B Vulnerability
- C Business Continuity
- D Loss Magnitude

Q104: Explanation

Correct Answer: A, B, D

FAIR quantifies risk using Threat Event Frequency, Vulnerability and Loss Magnitude.

- **A - Correct:** FAIR component.
- **B - Correct:** FAIR component.
- **C - Incorrect:** Not a FAIR component.
- **D - Correct:** FAIR component.

Q100: Quantitative Risk Analysis Update

Question

Which component is likely updated in risk register based on quantitative analysis?

A. Listing of risk responses
B. Risk ranking matrix
C. Listing of prioritized risks
D. Qualitative analysis outcomes

Q100: Explanation

Correct Answer: C

Quantitative analysis outcome creates listing of prioritized risks updated in risk register.

Option Analysis

- **A - Incorrect:** Responses from Plan Risk Response
- **B - Incorrect:** Matrix from qualitative
- **C - Correct:** Prioritized risks from quantitative
- **D - Incorrect:** Qualitative outcomes separate

CRISC Key Takeaways

Risk Management Fundamentals

- Risk management is an ongoing and iterative process.
- Risks must be identified, analyzed, assessed, monitored, and communicated continuously.
- New threats, vulnerabilities, technologies, and business objectives can create new risks at any time.
- Effective risk management aligns business objectives with risk appetite and risk tolerance.

CRISC Key Takeaways

Controls and Objective Achievement

- Controls exist to support achievement of business objectives.
- A control should be evaluated based on effectiveness, efficiency, and risk reduction.
- Strong controls with poor business alignment may still fail to support organizational goals.
- Control assessments should determine whether residual risk remains within acceptable limits.

CRISC Key Takeaways

Key Risk Indicators (KRIs)

- KRIs provide early warning signs of increasing risk.
- KRIs help management identify unfavorable trends before major incidents occur.
- KRIs are predictive and forward looking.
- Examples:
  - Increase in security incidents
  - Growing number of policy violations
  - Rising employee turnover
  - Increase in system downtime

CRISC Key Takeaways

Negative Risk Responses (Threats)

- Avoid: Eliminate the risk completely.
- Mitigate: Reduce likelihood or impact.
- Transfer: Shift risk to another party (insurance, outsourcing).
- Accept: Take no additional action and knowingly retain the risk.
- Risk ownership remains with the business.

CRISC Key Takeaways

Positive Risk Responses (Opportunities)

- Exploit: Ensure the opportunity occurs.
- Enhance: Increase probability or benefit.
- Share: Partner with another party to maximize benefit.
- Accept: Take advantage of the opportunity if it occurs.

CRISC Key Takeaways

Quantitative Risk Analysis

$$SLE = AV \times EF$$

$$ALE = SLE \times ARO$$

Where:

- AV = Asset Value
- EF = Exposure Factor
- SLE = Single Loss Expectancy
- ARO = Annualized Rate of Occurrence
- ALE = Annualized Loss Expectancy

Example: Asset Value = \$100,000 Exposure Factor = 40% ARO = 2 SLE = \$40,000 ALE = \$80,000

Most Important Exam Principle

Business Management Owns Risk

- Business management owns and accepts risk.
- The CRO provides oversight.
- IT supports business objectives.
- Security teams implement controls.
- Risk decisions belong to management.

CRISC Exam Essentials

Data Owner vs Data Custodian

Data Owner

- Classifies information
- Approves access
- Reviews user entitlements
- Determines protection requirements

Data Custodian

- Implements controls
- Maintains systems
- Performs backups
- Administers security tools

CRISC Exam Essentials

CIA Triad

- **Confidentiality** Protect information from unauthorized disclosure.
- **Integrity** Protect information from unauthorized modification.
- **Availability** Ensure information is available when needed.

Most security controls support one or more elements of the CIA Triad.

CRISC Exam Essentials

Capability Maturity Levels

- Level 0 – Nonexistent
- Level 1 – Initial / Ad Hoc
- Level 2 – Repeatable
- Level 3 – Defined
- Level 4 – Managed and Measurable
- Level 5 – Optimized

Exam Tip: If you see "continuous improvement," "optimization," or "best practices," think Level 5.

CRISC Exam Frameworks

Frameworks to Remember

- COBIT = IT Governance
- COSO ERM = Enterprise Risk Management
- FAIR = Quantitative Risk Analysis
- SABSA = Security Architecture
- Zachman = Enterprise Architecture Taxonomy
- PMBOK = Project Management

Final Advice

How to Answer CRISC Questions

1. Read the last sentence first.
2. Identify the role involved.
3. Determine who owns the risk.
4. Focus on business objectives.
5. Eliminate technically correct but less strategic answers.
6. Choose the BEST answer, not merely a correct answer.

Final Advice

Common CRISC Exam Traps

- Responsibility vs Accountability
- Risk Owner vs Risk Manager
- Compliance vs Security
- Detection vs Prevention
- Business Needs vs Technical Solution
- Governance vs Operations

In many questions, the most business-focused answer is the correct answer.

Final Advice

Good Luck on Your CRISC Exam!

Remember: **Business owns risk. Management makes**

risk decisions. Controls support business objectives.
Choose the BEST answer.